~\.bob\playground\ad_attack_lab\README.md

Active Directory Attack Lab

Kerberoasting Simulation & GPO Hardening in a Virtual Windows Domain

---

Overview

This project builds a self-contained virtual Windows Active Directory domain to demonstrate the **Kerberoasting** attack technique end-to-end and apply **Group Policy Object (GPO) hardening** to defend against it. Every phase — from SPN enumeration to hash cracking analysis to GPO remediation — is covered in both executable Python code and a full written report.

> ⚠️ **Disclaimer:** This lab is for **authorized educational and research use only**. Do not run these tools against any system you do not own or have explicit written permission to test.

Project Structure

```
ad_attack_lab/
├── kerberoast_lab.py      # Main Python simulation script
├── requirements.txt       # Python dependencies
├── REPORT.md              # Full project report (findings, GPO configs, remediation)
└── README.md              # This file
```

Lab Environment

Machine	Role	OS
DC01	Primary Domain Controller / KDC	Windows Server 2022
DC02	Replica Domain Controller	Windows Server 2022
WORKSTATION01	Attacker / Analyst	Windows 10 Enterprise
WEBSERVER01	Service Host (HTTP SPN)	Windows Server 2022
SQLSERVER01	Service Host (MSSQL SPN)	Windows Server 2022

- **Hypervisor:** VMware Workstation 17 Pro

- **Network:** Host-only (fully isolated)
- **Domain:** `lab.local` (Forest Functional Level: Windows Server 2016)

Attack Phases

Phase 1	SPN Enumeration setspn / ADSI / impacket GetUserSPNs.py
Phase 2	Kerberoasting — TGS Ticket Harvest Rubeus / impacket (TGT → TGS for each SPN)
Phase 3	Offline Hash Cracking Analysis Hashcat -m 13100 (RC4_HMAC etype 23)
Phase 4	GPO Hardening Disable RC4, enforce AES256, gMSA, audit
Phase 5	Detection & Monitoring Event 4769, MDI, SIEM KQL rules

---

Quick Start

1. Prerequisites

- Python 3.9+
- (Optional) VMware Workstation / VirtualBox for the full virtual lab
- (Optional) Windows Server 2022 ISO for DC setup

2. Install Dependencies

```
pip install -r requirements.txt
```

3. Run the Lab (Simulation Mode)

```
# Run all phases in simulation mode (no domain required)
```

```
python kerberoast_lab.py --simulate

# Run specific phase only
python kerberoast_lab.py --phase attack
python kerberoast_lab.py --phase gpo
python kerberoast_lab.py --phase remediate

# Custom domain and user
python kerberoast_lab.py --domain corp.internal --user pentest --simulate

# Save report to file
python kerberoast_lab.py --output lab_report.txt
```

4. Available CLI Options

Flag	Default	Description
`--domain`	`lab.local`	Target AD domain
`--user`	`attacker`	Attacker username
`--simulate`	`True`	Use built-in lab dataset (no domain needed)
`--phase`	`all`	`all`, `enum`, `attack`, `gpo`, `remediate`
`--output`	None	Save report to a text file

Key Concepts

What is Kerberoasting?

Kerberoasting is a **post-authentication credential access** technique that abuses a design property of the Kerberos protocol: any authenticated domain user can request a **TGS (service ticket)** for any registered SPN. The ticket is encrypted with the service account's password hash, enabling **offline brute-force cracking** with no account lockout risk.

```
Attacker  ──[TGT]──►  KDC  ──[TGS encrypted with svc_sql hash]──►
Attacker
                                └─── offline crack ─── plain password
```

Why RC4 is Dangerous

Encryption	Etype	Cracking Speed (RTX 3090)	Risk
RC4_HMAC	23	~500 MH/s	🔴 Critical

Encryption	Etype	Cracking Speed (RTX 3090)	Risk
AES128	17	~30 KH/s	🟡 Medium
AES256	18	~15 KH/s	🟢 Low

GPO Hardening Highlights

Disable RC4 Encryption (Most Critical)

```
GPO Path: Computer Configuration → Windows Settings → Security Settings
          → Local Policies → Security Options

Setting: Network security: Configure encryption types allowed for
Kerberos
Value:   AES128_HMAC_SHA1, AES256_HMAC_SHA1
```

Migrate to Group Managed Service Accounts (gMSA)

```
# Create gMSA (auto-rotating 240-char password — eliminates Kerberoasting risk)
New-ADServiceAccount -Name "gmsa_sql" `
    -DNSHostName "sqlserver01.lab.local" `
    -PrincipalsAllowedToRetrieveManagedPassword "Domain Computers" `
    -KerberosEncryptionType AES256

# Install on the target server
Install-ADServiceAccount -Identity gmsa_sql
```

Enable Kerberos Audit Logging

```
GPO Path: Computer Configuration → Windows Settings → Security Settings
          → Advanced Audit Policy Configuration → Account Logon

Setting: Audit Kerberos Service Ticket Operations → Success and Failure
Setting: Audit Kerberos Authentication Service    → Success and Failure
```

Detection

Windows Event ID 4769 — Kerberoast Indicator

```
Event ID : 4769  (Kerberos Service Ticket Requested)
Red flag : Ticket Encryption Type = 0x17 (RC4_HMAC)
           Multiple SPNs requested in short window from single source
```

SIEM Query (Microsoft Sentinel / KQL)

```
SecurityEvent
| where EventID == 4769
| where TicketEncryptionType == "0x17"
| summarize SPN_Count = dcount(ServiceName) by AccountName,
bin(TimeGenerated, 5m)
| where SPN_Count > 3
| project TimeGenerated, AccountName, SPN_Count
```

MITRE ATT&CK Coverage

Technique ID	Name	Phase
T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting	Credential Access
T1087.002	Account Discovery: Domain Account	Discovery
T1018	Remote System Discovery	Discovery
T1110.002	Brute Force: Password Cracking	Credential Access

Findings Summary

#	Finding	Severity	Fixed
F-01	RC4 encryption enabled for Kerberos	Critical	✅
F-02	Weak service account passwords	Critical	✅
F-03	No Kerberos audit logging	High	✅
F-04	Excessive SPN write permissions	Medium	✅
F-05	No gMSA in use	High	✅

References

- MITRE ATT&CK T1558.003 — Kerberoasting
- Microsoft Docs — Kerberos Authentication Overview
- Microsoft Docs — Group Managed Service Accounts
- CIS Microsoft Windows Server 2022 Benchmark
- Impacket — SecureAuth
- Rubeus — GhostPack
- Hashcat

License

This project is for **educational and authorized security research purposes only**.
Unauthorized use against systems you do not own is illegal and unethical.